Red-team playbook

How fraudsters adapt, and how the controls hold

Status: Draft v0.1 (2026-11-04), for Steve's review. Extension 10 of 10 (see the extensions overview). This playbook is about the durability of our detection controls. It describes adaptations at the level an agency risk office would discuss; it is not a guide to committing fraud.

Bottom line

Every published control teaches fraudsters what to avoid. A proposal that ignores this will be challenged by the first program official who has watched a scheme move from one program to the next. This playbook takes each control in the plan, names the obvious adaptation, says what signal the adaptation itself leaves, and states the counter. Four principles come out of it:

1. **Layer signals that are costly to fake together.** Avoiding one signal (a shared address) usually creates another (many new addresses registered the same week). Leads need two or more independent signals.
2. **Watch for the adaptation, not just the scheme.** Displacement is itself a signal: when a control tightens in one program, look for the same actors in the next program and the next state.
3. **Keep thresholds and weights private.** Publish methods at the level of the handbook, never the exact cut-offs or the feature weights.
4. **Re-validate on a schedule.** Every screen is re-tested quarterly on new confirmed cases, and drift in hit rates triggers review.

1. Adaptations by control

Control	Likely adaptation	Trace the adaptation leaves	Counter
Shared-address and shared-officer networks	One address and one nominee officer per entity	Bursts of new registrations, virtual-office and mailbox addresses, nominees appearing across many unrelated sectors	Co-location test on address type; registration-timing clusters; nominee screens across registries
Bank-account sharing	One account per entity, money moved on afterward	Accounts opened days before first payment, at the same few institutions; rapid outbound transfers	Account-age and account-owner verification at enrollment (Phase 2, with Treasury)

Control	Likely adaptation	Trace the adaptation leaves	Counter
Exclusion matching on name and identifiers	New entity with a relative or associate as owner	Same addresses, phones, staff or patients as the excluded entity	Linked-identity matching across attributes, not names; network seed propagation
Death and identity checks	Synthetic identities (real SSN fragments plus invented details)	Thin credit histories, identities that appear in only one program, shared devices	Cross-program identity age; device and contact sharing (Phase 2)
Billing-ramp and peer-outlier screens	Grow slowly; stay just inside peer ranges; spread billing across many entities	Many entities each at the 85th to 95th percentile; identical billing mixes	Distribution-shape tests across a group; cluster-level scoring rather than entity-level
Threshold bunching tests	Vary amounts randomly below the threshold	Too-uniform distributions; digit tests on the last two digits	Second-order and last-digit tests; bunching on a wider window
Benford and round-number tests	Use invented "random-looking" amounts	People are poor at random: too few repeats, too even digits	Number duplication and summation tests; compare to the entity's own history
Sealed-bid screens	Fake competition with a wider spread of cover bids	Cover bidders that never win, bid only against each other, or share preparers	Win-loss networks across tenders; rotation tests over time
Set-aside size and pass-through checks	Hide the large partner as a "mentor" or through a joint venture	Mentor-protege pairs where the protege does little of the work; sudden revenue jumps	Subaward and payroll share checks; front-company profile
Cross-agency matching	Move to a program or state not yet in the match	Same actors appearing in new programs after a control goes live	Displacement watch list; prioritize the next programs for matching
Tip triage	Flood hotlines with low-quality tips about competitors or to bury a real tip	Bursts of similar tips from one source or template	Duplicate and campaign detection; tip source analysis
Pre-payment checks	Target programs or periods with pay-first rules (emergencies)	Spikes in new payees in emergency programs	Emergency playbooks with identity verification that is fast, not absent

2. Pushback we should expect, and the answer

Pushback	Answer
"Fraudsters will just adapt."	Yes; that is why controls are layered and re-validated, and why adaptation leaves its own trace (table above). Every adaptation raises the cost of the fraud.
"Your false positives will hurt legitimate providers and beneficiaries."	No action is taken on a score. Leads go to trained reviewers, each screen states its false-positive rate, and release requires 5x lift and bias checks.



Pushback	Answer
"Publishing your methods teaches them."	We publish the method class, not thresholds or weights. Academic and GAO literature already describes the methods; the advantage is in data and execution.
"We already do this."	Then the pilot measures our marginal value directly: the new-detection rate against what the agency already knows. If it is below break-even, we stop.
"The data will never be shared."	Most of Phase 1 runs on public data, and the legal routes for Phase 2 exist (see the policy and legal track).

3. Running a red-team exercise

Twice a year, and before any screen's first release:

1. A team member not involved in building the screen takes the role of a fraud organizer and writes down how they would avoid it, using only what is public.
2. The team builds a synthetic version of the adapted scheme and runs the full screen set on it.
3. Each adaptation is scored: caught by another screen, caught by the adaptation's own trace, or missed.
4. Misses become backlog items with an owner; results go into the screen's model documentation.

4. Questions for Steve

1. Should we invite an OIG investigator or a former prosecutor to the first red-team session?
2. How much of the method do we put on the public parts of the site? The current site is password-protected; this playbook assumes the thresholds stay off any public page.

